



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

Proyecto Final

Autor (es):

Quezada Gallardo, Angelo Diancarlo – aquezadag1@miumg.edu.gt

Sosa Arroyo, Danny Josué – dsosaa1@miumg.edu.gt

Girón Rodriguez, Katherine Mishell - kgironr5@miumg.edu.gt

Arango Garcia, Josue David - jgarciaa53@miumg.edu.gt

Salazar Nájera, Javier Eduardo - jsalazarn@miumg.edu.gt

Profesor

CESAR GIOVANNI RODRIGUEZ MINAS

Curso

SEGURIDAD DE SISTEMAS INFORMÁTICO

Guatemala, 2026

Tabla de contenido

Introducción	6
MARCO TEÓRICO.....	7
Seguridad de la información y la tríada CID	7
Gestión de riesgos de seguridad de la información	7
Metodología MAGERIT.....	7
Metodología OCTAVE Allegro	8
Modelo de defensa en profundidad	8
OWASP Top 10 y seguridad de aplicaciones.....	8
Síntesis del marco teórico.....	9
METODOLOGÍA.....	9
Alcance y activos evaluados.....	9
Identificación de activos, amenazas y vulnerabilidades	9
Evaluación del riesgo con MAGERIT.....	10
Evaluación del riesgo con OCTAVE Allegro	10
Clasificación y tratamiento del riesgo	10
ACTIVO 1 (Ambiente de Producción): Sistema ERP / Facturación (Software).....	11
Riesgo 1: Infección por Ransomware afectando la disponibilidad	11
Riesgo 2: Ataque de Inyección SQL (SQLi).....	11
Riesgo 3: Robo de credenciales mediante Phishing	12
ACTIVO 2 (Ambiente de Pruebas): Ambiente de Staging Web (Software)	13
Riesgo 1: Fuga de datos de producción por clonación sin sanitizar	13
Riesgo 2: Exposición perimetral del entorno de pruebas	14
Riesgo 3: Vulnerabilidades heredadas en dependencias de software.....	14

ACTIVO 3 (Ambiente de Desarrollo): Repositorio de Código (Git) (Software)	15
Riesgo 1: Exposición de credenciales dentro del código fuente	15
Riesgo 2: Inyección de código malicioso por compromiso de cuenta	16
Riesgo 3: Pérdida de historial de ramas principales	17
Activo 1 (Ambiente de Producción): Administrador de sistemas	18
Riesgo 1: Abuso de privilegios administrativos sobre la infraestructura de producción	18
Riesgo 2: Punto único de conocimiento y dependencia operativa	19
Riesgo 3: Ingeniería social y compromiso de credenciales del administrador	19
Activo 2 (Ambiente de Pruebas): QA Tester.....	20
Riesgo 1: Manejo indebido de datos en el ambiente de pruebas.....	20
Riesgo 2: Validación de calidad deficiente que permite el paso de defectos de seguridad ...	21
Riesgo 3: Acceso residual y credenciales del QA Tester en el ambiente de pruebas	22
Activo 3 (Ambiente de Desarrollo): Desarrollador	22
Riesgo 1: Introducción de código inseguro o malicioso	22
Riesgo 2: Exposición de credenciales y secretos en el código fuente.....	23
Riesgo 3: Uso de estación de trabajo del desarrollador como vector de compromiso	24
Consolidación del Tratamiento de Riesgos / Solución por Criticidad	25
EVALUACIÓN DE RIESGOS POR ACTIVO ASIGNADO.....	25
Activo 1 (Ambiente de Producción): Datos de clientes	25
Riesgo 1: Acceso no autorizado a la base de datos de producción	25
Riesgo 2: Exposición de información por deficiencias de cifrado	26
Riesgo 3: Uso indebido de privilegios por parte de personal interno	27
Activo 2 (Ambiente de Pruebas): Datos de prueba anonimizados	28
Riesgo 1: Anonimización insuficiente y reidentificación de datos	28
Riesgo 2: Acceso no controlado al ambiente de pruebas	29

Riesgo 3: Retención prolongada de datos de prueba obsoletos	29
Activo 3 (Ambiente de Desarrollo): Código fuente y credenciales.....	30
Riesgo 1: Exposición de credenciales dentro del código fuente	30
Riesgo 2: Acceso no autorizado al repositorio de código fuente	31
Riesgo 3: Ausencia de verificación de integridad del código	32
Consolidación del Tratamiento de Riesgos / Solución por Criticidad.....	32
EVALUACIÓN DE RIESGOS POR ACTIVO ASIGNADO.....	33
Activo 1 (Ambiente de Producción): Servidor de Base de Datos	33
Riesgo 1: Acceso físico no controlado al centro de datos.....	33
Riesgo 2: Exposición de puertos de administración a la red interna.....	33
Riesgo 3: Sistema operativo del servidor desactualizado	34
Riesgo 4: Configuración por defecto del motor de base de datos	35
Riesgo 5: Ausencia de cifrado en datos en reposo	36
Riesgo 6: Cuentas administrativas compartidas.....	37
Riesgo 7: Falta de registro centralizado de eventos	38
Riesgo 8: RespalDOS no probados periódicamente	38
Riesgo 9: Reglas de firewall obsoletas.....	39
Riesgo 10: Falta de procedimiento de gestión de parches	40
Activo 2 (Ambiente de Pruebas): Servidor de pruebas	41
Riesgo 1: Ubicación física sin resguardo del servidor de pruebas	41
Riesgo 2: Ausencia de segmentación hacia el ambiente de producción	42
Riesgo 3: Servidor de pruebas sin bastionado (hardening)	43
Riesgo 4: Ausencia de aislamiento entre proyectos de prueba	43
Riesgo 5: Discos sin cifrado en el servidor de pruebas.....	44
Riesgo 6: Credenciales de acceso compartidas al servidor	45

Riesgo 7: Falta de monitoreo de disponibilidad y accesos.....	46
Riesgo 8: Ausencia de respaldo del servidor de pruebas	47
Riesgo 9: Exposición directa del servidor de pruebas a Internet	47
Riesgo 10: Ausencia de un ciclo de vida formal del servidor de pruebas.....	48
Activo 3 (Ambiente de Desarrollo): Estación de trabajo del desarrollador	49
Riesgo 1: Ausencia de bloqueo automático en equipos móviles	49
Riesgo 2: Conexión a redes no confiables sin VPN.....	50
Riesgo 3: Estación de trabajo sin actualizaciones ni antimalware	51
Riesgo 4: Instalación de software no autorizado.....	51
Riesgo 5: Código fuente y credenciales sin cifrado local	52
Riesgo 6: Privilegios de administrador local permanentes	53
Riesgo 7: Ausencia de telemetría de seguridad en el equipo	54
Riesgo 8: Trabajo almacenado únicamente de forma local.....	55
Riesgo 9: Acceso remoto sin restricción de origen ni dispositivo	55
Riesgo 10: Falta de proceso formal de baja de equipos	56
Conclusión	58
Referencias.....	59

Introducción

En la actualidad, la seguridad de la información constituye un elemento fundamental para garantizar la continuidad, confiabilidad y protección de los sistemas que soportan las operaciones de una organización. La creciente dependencia de plataformas tecnológicas, bases de datos, aplicaciones y ambientes de desarrollo incrementa la exposición ante amenazas que pueden comprometer la confidencialidad, integridad y disponibilidad de la información. En este contexto, la gestión de riesgos permite identificar de manera estructurada las amenazas y vulnerabilidades que pueden afectar los activos, valorar su probabilidad e impacto y establecer medidas de tratamiento acordes con su nivel de criticidad.

El presente trabajo desarrolla un análisis de riesgos de seguridad de la información aplicado a diferentes activos y ambientes tecnológicos de una organización, considerando los entornos de producción, pruebas y desarrollo, así como los recursos humanos relacionados con su operación. Para ello, se emplean metodologías como MAGERIT y OCTAVE Allegro, complementadas con el modelo de defensa en profundidad y los principios establecidos en el OWASP Top 10, con el propósito de identificar escenarios de riesgo, determinar las dimensiones de seguridad comprometidas y establecer medidas de mitigación.

A partir de este análisis se examinan riesgos asociados con ransomware, inyección SQL, phishing, exposición de credenciales, accesos no autorizados, configuraciones inseguras, vulnerabilidades de software, manejo de información en ambientes de prueba y debilidades relacionadas con los procesos de desarrollo. Asimismo, se plantean soluciones específicas orientadas a reducir la probabilidad de materialización de las amenazas y limitar su impacto sobre los activos críticos de la organización. De esta manera, el trabajo busca demostrar la importancia de adoptar un enfoque preventivo y estructurado de la gestión de riesgos, en el que los controles tecnológicos, los procesos organizacionales y el factor humano funcionen de manera integrada para fortalecer la seguridad de la información.

MARCO TEÓRICO

El presente trabajo se fundamenta en un conjunto de conceptos, metodologías y estándares propios de la seguridad de la información, orientados a identificar, valorar y tratar los riesgos que afectan a los activos de una organización. A continuación se desarrollan los términos clave que sustentan el análisis realizado.

Seguridad de la información y la tríada CID

La seguridad de la información es el conjunto de principios, políticas y controles orientados a proteger los activos de información frente a amenazas que puedan comprometer su valor para la organización. Su fundamento conceptual es la tríada CID, integrada por la confidencialidad, que garantiza que la información solo sea accesible para quienes están autorizados a conocerla; la integridad, que asegura que los datos no sean alterados de forma no autorizada o accidental; y la disponibilidad, que garantiza el acceso oportuno a la información y a los sistemas cuando estos son requeridos. A estas dimensiones básicas, marcos como MAGERIT añaden la autenticidad, que certifica el origen legítimo de la información o de quien la genera, y la trazabilidad, que permite reconstruir quién realizó una acción determinada y en qué momento (Ministerio de Hacienda y Administraciones Públicas, 2012a).

Gestión de riesgos de seguridad de la información

La gestión de riesgos es el proceso sistemático mediante el cual una organización identifica sus activos de información, reconoce las amenazas que podrían afectarlos y las vulnerabilidades que estas amenazas podrían explotar, para luego estimar la probabilidad de ocurrencia y el impacto potencial de cada escenario. Con base en esa estimación se determina el nivel de riesgo y se define su tratamiento, que puede consistir en mitigarlo mediante controles, transferirlo a un tercero, evitarlo o aceptarlo formalmente. La norma ISO/IEC 27005 (2018) establece las directrices internacionales para este proceso, proporcionando un marco de referencia común que numerosas metodologías nacionales, como MAGERIT, adoptan y adaptan a su propio contexto.

Metodología MAGERIT

MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información) es una metodología desarrollada por el Gobierno de España que ofrece un método estructurado para analizar los riesgos que afectan a los sistemas de información y para planificar el tratamiento oportuno de dichos riesgos. Su enfoque valora cada activo según las dimensiones

de seguridad que podrían verse comprometidas confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad y calcula el riesgo resultante a partir de la combinación entre la probabilidad de que la amenaza se materialice y el impacto que esta generaría sobre el activo. Este cálculo permite clasificar los riesgos en niveles como moderado, alto o crítico, facilitando la priorización de las medidas de mitigación (Ministerio de Hacienda y Administraciones Públicas, 2012a, 2012b).

Metodología OCTAVE Allegro

OCTAVE Allegro es un enfoque de evaluación de riesgos desarrollado por el Software Engineering Institute de la Universidad Carnegie Mellon, orientado principalmente a los activos de información considerados esenciales para la organización. A diferencia de metodologías centradas en la infraestructura tecnológica, OCTAVE Allegro parte del activo de información y analiza los contenedores donde este reside ya sean sistemas, personas o instalaciones físicas, el actor que representa la amenaza y el requisito de seguridad que resultaría afectado en caso de materializarse el riesgo. Este enfoque complementa a MAGERIT al aportar una perspectiva centrada en el valor del activo para el negocio y en la prioridad de protección que este merece (Caralli et al., 2007).

Modelo de defensa en profundidad

La defensa en profundidad es un principio de diseño de seguridad que propone la implementación de múltiples capas de control complementarias, de manera que si un atacante logra vulnerar una de ellas, las capas restantes continúen protegiendo el activo. Estas capas suelen incluir la seguridad física de las instalaciones, la seguridad de red mediante segmentación y firewalls, la seguridad de host referida a la protección de servidores y equipos individuales, la seguridad de aplicación orientada al software y su código, la seguridad de datos centrada en el cifrado y control de acceso a la información, y la capa humana, que abarca la concienciación y el comportamiento de las personas frente a amenazas como la ingeniería social. Este modelo permite estructurar de forma ordenada las soluciones de mitigación propuestas para cada riesgo identificado.

OWASP Top 10 y seguridad de aplicaciones

El proyecto OWASP (Open Web Application Security Project) publica de forma periódica el documento OWASP Top 10, un catálogo de referencia internacional que resume los riesgos más críticos y frecuentes en aplicaciones web, entre ellos la inyección de código (como la inyección SQL), el control de acceso deficiente y la exposición de datos sensibles. Este catálogo constituye

una guía práctica ampliamente adoptada por la industria para orientar las prácticas de codificación segura, la validación de entradas y las revisiones de seguridad durante el ciclo de vida del desarrollo de software (OWASP Foundation, 2021).

Síntesis del marco teórico

En conjunto, estos conceptos y metodologías conforman la base conceptual sobre la cual se desarrolla el análisis de riesgos del presente trabajo: la tríada CID y sus dimensiones extendidas permiten definir qué se protege; ISO/IEC 27005 aporta el proceso general de gestión de riesgos; MAGERIT y OCTAVE Allegro ofrecen métodos complementarios para valorar y priorizar dichos riesgos; el modelo de defensa en profundidad organiza las soluciones de mitigación por capas; y el OWASP Top 10 orienta las medidas específicas de seguridad en el ámbito del desarrollo de aplicaciones

METODOLOGÍA

El presente trabajo se desarrolló bajo un enfoque cualitativo de tipo descriptivo, aplicando de forma estructurada las metodologías MAGERIT y OCTAVE Allegro para la identificación, valoración y tratamiento de los riesgos de seguridad de la información. El procedimiento se ejecutó en las fases que se describen a continuación.

Alcance y activos evaluados

El análisis se realizó sobre los tres ambientes en los que opera la organización producción, pruebas y desarrollo cubriendo cuatro categorías de activos: activos de software (sistema ERP/facturación, ambiente de staging web y repositorio de código en Git), activos de recursos humanos (administrador de sistemas, QA Tester y desarrollador), activos de información o datos (datos de clientes, datos de prueba anonimizados, y código fuente con credenciales) y activos de infraestructura (servidor de base de datos, servidor de pruebas y estación de trabajo del desarrollador). Cada categoría de activos fue asignada a un integrante del equipo, quien fue responsable de identificar, evaluar y proponer el tratamiento de los riesgos correspondientes a su ambiente asignado.

Identificación de activos, amenazas y vulnerabilidades

Para cada activo se identificó, en primer lugar, la brecha o debilidad de seguridad presente (por ejemplo, ausencia de autenticación multifactor, configuración por defecto o falta de cifrado), y a partir de ella se determinó la amenaza correspondiente, entendida como el actor y el evento

que podría explotar dicha brecha. Este ejercicio se documentó de forma individual para cada riesgo, indicando además la capa de seguridad por profundidad que se vería comprometida (física, de red, de host, de aplicación, de datos o humana), conforme al modelo de defensa en profundidad.

Evaluación del riesgo con MAGERIT

Cada riesgo identificado fue evaluado aplicando la escala de valoración de MAGERIT, estimando la probabilidad de ocurrencia (baja, media o alta) y el impacto sobre una escala de 1 a 10, así como las dimensiones de seguridad comprometidas (confidencialidad, integridad, disponibilidad, autenticidad o trazabilidad). A partir de la combinación de probabilidad e impacto se determinó el nivel de riesgo resultante, clasificado en las categorías moderado, alto o crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).

Evaluación del riesgo con OCTAVE Allegro

De forma complementaria, cada riesgo se evaluó bajo el enfoque OCTAVE Allegro, identificando el actor responsable de la amenaza (interno malicioso, interno negligente o externo), el contenedor donde reside el activo afectado, el requisito de seguridad comprometido y la prioridad de protección asignada al activo, en función de su relevancia operativa, financiera o reputacional para la organización (Caralli et al., 2007).

Clasificación y tratamiento del riesgo

Con base en los resultados obtenidos de ambas metodologías, los riesgos se ubicaron en una matriz de calor que permitió visualizar de manera conjunta su probabilidad e impacto, facilitando la priorización de los riesgos críticos y altos. Para cada riesgo se definió un tratamiento (mitigar, controlar, transferir, evitar o aceptar) y se propuso una solución específica de mitigación, alineada con buenas prácticas de la industria como el modelo de defensa en profundidad, el estándar OWASP Top 10 (OWASP Foundation, 2021) y los lineamientos de gestión de riesgos de la norma ISO/IEC 27005 (2018).

ANÁLISIS DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

ACTIVO 1 (Ambiente de Producción): Sistema ERP / Facturación (Software)

Riesgo 1: Infección por Ransomware afectando la disponibilidad

Capa de Seguridad por Profundidad	Capa de host y capa de red, dentro del modelo de defensa en profundidad.
Brecha	Ausencia de controles antimalware avanzados y políticas de respaldo inmutables.
Amenaza	Actor externo que despliega malware cifrando las bases de datos de facturación, impidiendo el acceso a los datos.
Evaluación MAGERIT	Probabilidad: alta. Impacto: 9 (muy alto), según la escala de valoración de MAGERIT. Dimensión comprometida: disponibilidad [D]. Riesgo resultante: crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).
Evaluación OCTAVE	Activo de información esencial dentro del enfoque OCTAVE Allegro. Actor: externo. Contenedor: servidor de base de datos de producción. Requisito de seguridad afectado: disponibilidad. Prioridad de protección: muy alta, por tratarse del activo con mayor peso en los criterios de impacto financiero y operativo (Caralli et al., 2007).
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Implementar soluciones EDR (Endpoint Detection and Response) en servidores y mantener respaldos inmutables offline.

Riesgo 2: Ataque de Inyección SQL (SQLi)

Capa de Seguridad por Profundidad	Capa de aplicación y capa de datos, dentro del modelo de defensa en profundidad.
Brecha	Validación de entradas insuficiente en el sistema ERP, lo que permite consultas no previstas sobre la base de datos.

Amenaza	Actor externo que aprovecha una vulnerabilidad de inyección (por ejemplo, inyección SQL) para extraer o modificar datos de facturación.
Evaluación MAGERIT	Probabilidad: alta. Impacto: 8 (alto), según la escala de valoración de MAGERIT. Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: alto (Ministerio de Hacienda y Administraciones Públicas, 2012b).
Evaluación OCTAVE	Activo de información esencial dentro del enfoque OCTAVE Allegro. Actor: externo. Contenedor: aplicación ERP y base de datos. Requisito de seguridad afectado: confidencialidad e integridad. Prioridad de protección: alta, por el impacto reputacional y regulatorio (Caralli et al., 2007).
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Uso de consultas parametrizadas u ORM, implementación de un firewall de aplicaciones web (WAF), y revisiones periódicas de código seguro, en línea con las recomendaciones del OWASP Top 10 (OWASP Foundation, 2021).

Riesgo 3: Robo de credenciales mediante Phishing

Capa de Seguridad por Profundidad	Capa humana y capa de aplicación (gobierno de accesos).
Brecha	Ausencia de autenticación multifactor (MFA) y concientización deficiente contra ingeniería social.
Amenaza	Colaborador con acceso legítimo que es engañado para entregar sus credenciales, permitiendo el ingreso no autorizado al ERP.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto), según la escala de valoración de MAGERIT. Dimensión comprometida: confidencialidad [C]. Riesgo resultante: alto (Ministerio de Hacienda y Administraciones Públicas, 2012b).

Evaluación OCTAVE	Actor: externo (mediante suplantación) o interno negligente. Contenedor: aplicación ERP. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por evidenciar una debilidad de gobierno interno (Caralli et al., 2007).
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar y controlar.
Solución Específica de Mitigación	Exigir Autenticación Multifactor (MFA) obligatoria para todo acceso al ERP y aplicar programas periódicos de capacitación en seguridad de la información.

ACTIVO 2 (Ambiente de Pruebas): Ambiente de Staging Web (Software)

Riesgo 1: Fuga de datos de producción por clonación sin sanitizar

Capa de Seguridad por Profundidad	Capa de aplicación y capa de datos.
Brecha	Proceso de anonimización débil al migrar o clonar la base de datos de producción al entorno de staging.
Amenaza	Exposición de información sensible o reidentificación de personas mediante la correlación de los datos de prueba con otras fuentes de información disponibles.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: interno negligente o tercero con acceso al ambiente. Contenedor: base de datos de pruebas. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por el impacto reputacional y regulatorio asociado a datos personales (Caralli et al., 2007).
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.

Solución Específica de Mitigación	Implementar herramientas de enmascaramiento dinámico de datos (Data Masking) y validación periódica de la efectividad del proceso de anonimización.
--	---

Riesgo 2: Exposición perimetral del entorno de pruebas

Capa de Seguridad por Profundidad	Capa de red y capa de aplicación.
Brecha	Ausencia de segmentación de red o configuración que permita la indexación y acceso público al entorno de staging.
Amenaza	Persona no autorizada, incluyendo contratistas externos, accede al ambiente de pruebas o escáneres públicos detectan la infraestructura.
Evaluación MAGERIT	Probabilidad: media. Impacto: 5 (medio). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: externo (contratista o tercero) o interno negligente. Contenedor: red y credenciales del ambiente de pruebas. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media, por su conexión indirecta con activos críticos de producción (Caralli et al., 2007).
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Restringir el acceso web mediante lista blanca de IPs (VPN corporativa), segmentación de red mediante VLAN dedicada y autenticación obligatoria.

Riesgo 3: Vulnerabilidades heredadas en dependencias de software

Capa de Seguridad por Profundidad	Capa de aplicación.
Brecha	Uso de librerías de terceros desactualizadas o con fallos de seguridad conocidos desplegadas en el código de staging.

Amenaza	Actor externo que explota vulnerabilidades públicas (CVEs) para comprometer el servicio web, interrumpiendo su funcionamiento.
Evaluación MAGERIT	Probabilidad: media. Impacto: 5 (medio). Dimensión comprometida: disponibilidad [D]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: externo. Contenedor: aplicación web en staging. Requisito de seguridad afectado: disponibilidad. Prioridad de protección: media, relevante sobre todo por el cumplimiento normativo y para prevenir el escalamiento de privilegios.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Ejecutar análisis DAST y SAST en el pipeline antes del despliegue a staging, junto a revisiones periódicas de código seguro.

ACTIVO 3 (Ambiente de Desarrollo): Repositorio de Código (Git) (Software)

Riesgo 1: Exposición de credenciales dentro del código fuente

Capa de Seguridad por Profundidad	Capa de aplicación.
Brecha	Prácticas de codificación deficientes que incluyen credenciales escritas directamente en el código (hardcoded secrets) y ausencia de escaneo automatizado de secretos.
Amenaza	Filtración de credenciales a través de un repositorio comprometido, permitiendo el acceso no autorizado a sistemas críticos.
Evaluación MAGERIT	Probabilidad: alta. Impacto: 9 (muy alto), según la escala de valoración de MAGERIT. Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).
Evaluación OCTAVE	Actor: externo que explota credenciales filtradas, o interno negligente. Contenedor: repositorio de código y flujos de integración continua (CI/CD). Requisito de seguridad afectado: confidencialidad. Prioridad de protección: muy alta, ya que

	compromete potencialmente la totalidad de los sistemas conectados (Caralli et al., 2007).
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Configuración de ganchos (hooks) de pre-commit con escáneres de secretos (ej. TruffleHog), implementación de un gestor centralizado de secretos, escaneo automático de credenciales dentro de los flujos de integración continua (CI/CD) y rotación periódica de credenciales.

Riesgo 2: Inyección de código malicioso por compromiso de cuenta

Capa de Seguridad por Profundidad	Capa de aplicación y capa de red.
Brecha	Controles de acceso débiles al repositorio, sin autenticación multifactor.
Amenaza	Compromiso de la cuenta de un desarrollador para la inserción de código malicioso por parte de un actor no autorizado.
Evaluación MAGERIT	Probabilidad: media. Impacto: 9 (muy alto). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: crítico.
Evaluación OCTAVE	Actor: externo o interno comprometido. Contenedor: plataforma de control de versiones (repositorio Git). Requisito de seguridad afectado: integridad. Prioridad de protección: muy alta, por la pérdida potencial de ventaja competitiva y el daño hacia los usuarios finales.
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Forzar el firmado criptográfico de commits (GPG), exigir autenticación multifactor obligatoria, y establecer revisión

obligatoria de solicitudes de cambio (pull requests) antes de su integración.

Riesgo 3: Pérdida de historial de ramas principales

Capa de Seguridad por Capa de aplicación.

Profundidad

Brecha Permisos excesivos otorgados a usuarios y carencia de restricciones administrativas sobre ramas vitales.

Amenaza Borrado accidental o intencional de ramas principales del repositorio, paralizando la entrega de software.

Evaluación MAGERIT Probabilidad: baja. Impacto: 5 (medio). Dimensión comprometida: disponibilidad [D]. Riesgo resultante: moderado.

Evaluación OCTAVE Actor: interno malicioso o interno negligente. Contenedor: plataforma de control de versiones (repositorio Git). Requisito de seguridad afectado: disponibilidad. Prioridad de protección: media, por su efecto sobre la continuidad operativa de los desarrolladores.

Nivel de Riesgo Moderado

Resultante

Tratamiento del Riesgo Mitigar.

Solución Específica de Mitigación Habilitar políticas de protección de ramas (branch protection) impidiendo operaciones destructivas como el force push, y aplicar control de acceso basado en roles.

EVALUACIÓN DE RIESGOS POR ACTIVO ASIGNADO

Responsable: Josue. Activos de tipo Recursos Humanos en los ambientes de Producción, Pruebas y Desarrollo.

Activo 1 (Ambiente de Producción): Administrador de sistemas

Riesgo 1: Abuso de privilegios administrativos sobre la infraestructura de producción

Capa de Seguridad por Profundidad	Capa humana y capa de aplicación (gobierno de accesos), dentro del modelo de defensa en profundidad.
Brecha	Ausencia de segregación de funciones y de auditoría sobre las cuentas con privilegios administrativos, concentrando el control total de la infraestructura en una sola persona.
Amenaza	Administrador con acceso legítimo que, de forma deliberada o negligente, modifica configuraciones, extrae información o deshabilita controles de seguridad sin justificación de negocio (amenaza interna).
Evaluación MAGERIT	Probabilidad: media. Impacto: 9 (muy alto), según la escala de valoración de MAGERIT. Dimensiones comprometidas: confidencialidad [C], integridad [I] y disponibilidad [D]. Riesgo resultante: crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).
Evaluación OCTAVE	Activo humano crítico dentro del enfoque OCTAVE Allegro. Actor: interno malicioso o interno negligente. Contenedor: cuentas privilegiadas sobre servidores, firewall y base de datos de producción. Requisito de seguridad afectado: confidencialidad e integridad. Prioridad de protección: muy alta, por concentrar el mayor peso operativo de la organización (Caralli et al., 2007).
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar y controlar.
Solución Específica de Mitigación	Aplicación del principio de mínimo privilegio, segregación de funciones, uso de cuentas nominales en lugar de compartidas, gestión

de accesos privilegiados (PAM) con doble autorización para operaciones sensibles y registro con trazabilidad independiente.

Nota. Elaboración Propia

Riesgo 2: Punto único de conocimiento y dependencia operativa

Capa de Seguridad por Capa humana y capa de gobierno (continuidad operativa).

Profundidad

Brecha Falta de documentación de la configuración y ausencia de un respaldo de personal capacitado, lo que genera dependencia total de una sola persona (bus factor de uno).

Amenaza Ausencia imprevista del administrador (renuncia, incapacidad o indisponibilidad) que impide operar, mantener o recuperar los sistemas de producción.

Evaluación MAGERIT Probabilidad: media. Impacto: 8 (alto). Dimensión comprometida: disponibilidad [D]. Riesgo resultante: alto.

Evaluación OCTAVE Actor: interno (indisponibilidad de personal). Contenedor: conocimiento operativo no documentado de la infraestructura. Requisito de seguridad afectado: disponibilidad. Prioridad de protección: alta, por su efecto directo sobre la continuidad del servicio.

Nivel de Riesgo Alto

Resultante

Tratamiento del Riesgo Mitigar.

Solución Específica de Mitigación Documentación formal de procedimientos operativos, respaldos de configuración, capacitación cruzada de al menos un segundo responsable y planes de continuidad y sucesión del rol.

Nota. Elaboración Propia

Riesgo 3: Ingeniería social y compromiso de credenciales del administrador

Capa de Seguridad por Capa humana y capa de identidad y acceso.

Profundidad

Brecha Concienciación insuficiente en seguridad y ausencia de autenticación multifactor sobre las cuentas privilegiadas del administrador.

Amenaza	Actor externo que, mediante phishing o ingeniería social, obtiene las credenciales del administrador y accede a los sistemas críticos de producción.
Evaluación MAGERIT	Probabilidad: media. Impacto: 9 (muy alto). Dimensiones comprometidas: confidencialidad [C], integridad [I] y disponibilidad [D]. Riesgo resultante: crítico.
Evaluación OCTAVE	Actor: externo. Contenedor: credenciales privilegiadas y estación de trabajo del administrador. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: muy alta, por el alcance de una cuenta con control total.
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Autenticación multifactor obligatoria para todas las cuentas privilegiadas, programas periódicos de concienciación y simulaciones de phishing, y monitoreo de inicios de sesión anómalos.

Nota. Elaboración Propia

Activo 2 (Ambiente de Pruebas): QA Tester

Riesgo 1: Manejo indebido de datos en el ambiente de pruebas

Capa de Seguridad por Profundidad	Capa humana y capa de datos.
Brecha	Falta de control sobre los datos utilizados en las pruebas, con riesgo de que se empleen datos reales de clientes en lugar de datos anonimizados.
Amenaza	QA Tester que, por error o práctica indebida, carga o exporta información sensible real dentro del ambiente de pruebas, exponiéndola fuera de los controles de producción.
Evaluación MAGERIT	Probabilidad: media. Impacto: 6 (medio). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: moderado.

Evaluación OCTAVE	Actor: interno negligente. Contenedor: ambiente de pruebas y conjuntos de datos utilizados. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media, relevante por el cumplimiento normativo en materia de protección de datos personales.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Uso obligatorio de datos anonimizados o sintéticos, prohibición de datos productivos en pruebas verificada mediante controles automáticos y capacitación en manejo seguro de datos.

Nota. Elaboración Propia

Riesgo 2: Validación de calidad deficiente que permite el paso de defectos de seguridad

Capa de Seguridad por Profundidad	Capa humana y capa de aplicación (aseguramiento de calidad).
Brecha	Cobertura insuficiente de casos de prueba de seguridad y ausencia de criterios de aceptación que incluyan requisitos de seguridad.
Amenaza	Defectos o vulnerabilidades que no son detectados durante las pruebas y se propagan hacia el ambiente de producción.
Evaluación MAGERIT	Probabilidad: media. Impacto: 7 (alto). Dimensiones comprometidas: integridad [I] y disponibilidad [D]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: interno (error humano en la validación). Contenedor: proceso de aseguramiento de calidad y suite de pruebas. Requisito de seguridad afectado: integridad. Prioridad de protección: media-alta, por su efecto sobre la calidad del producto entregado a producción.
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.

Solución Específica de Mitigación	Incorporación de casos de prueba de seguridad, criterios de aceptación con requisitos de seguridad, pruebas automatizadas dentro del pipeline y revisión de cobertura de manera periódica.
--	--

Nota. Elaboración Propia

Riesgo 3: Acceso residual y credenciales del QA Tester en el ambiente de pruebas

Capa de Seguridad por Profundidad	Capa humana y capa de identidad y acceso.
Brecha	Uso de credenciales compartidas entre miembros del equipo de pruebas y permisos que no se revocan tras la finalización de tareas o proyectos.
Amenaza	Persona no autorizada que reutiliza credenciales activas del QA Tester para acceder al ambiente de pruebas y a la información allí contenida.
Evaluación MAGERIT	Probabilidad: media. Impacto: 6 (medio). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: externo (contratista o tercero) o interno negligente. Contenedor: credenciales y accesos del ambiente de pruebas. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media, por su conexión indirecta con activos de producción.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Credenciales nominales e individuales, revisión periódica de accesos, revocación oportuna de permisos al finalizar tareas y autenticación multifactor en el ambiente de pruebas.

Nota. Elaboración Propia

Activo 3 (Ambiente de Desarrollo): Desarrollador

Riesgo 1: Introducción de código inseguro o malicioso

Capa de Seguridad por Profundidad	Capa humana y capa de aplicación.
--	-----------------------------------

Brecha	Ausencia de prácticas de codificación segura y de revisión de código obligatoria antes de la integración de los cambios.
Amenaza	Desarrollador que, de forma negligente o deliberada, introduce vulnerabilidades o código malicioso que se propaga hacia pruebas y producción.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensiones comprometidas: integridad [I] y confidencialidad [C]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: interno malicioso o interno negligente. Contenedor: código fuente y pipeline de desarrollo. Requisito de seguridad afectado: integridad. Prioridad de protección: alta, por su efecto en la cadena de entrega del software (Caralli et al., 2007).
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Revisión de código obligatoria (pull requests), análisis estático de seguridad (SAST) en el pipeline, capacitación en codificación segura conforme al OWASP Top 10 (OWASP Foundation, 2021) y protección de ramas.

Nota. Elaboración Propia

Riesgo 2: Exposición de credenciales y secretos en el código fuente

Capa de Seguridad por Profundidad	Capa humana y capa de datos.
Brecha	Prácticas inadecuadas de gestión de secretos que llevan a incrustar credenciales, llaves o tokens directamente en el código o en el repositorio.
Amenaza	Filtración de credenciales incluidas en el código que un actor externo aprovecha para acceder a servicios y sistemas conectados.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: alto.

Evaluación OCTAVE	Actor: externo o interno negligente. Contenedor: repositorio de código y entorno de desarrollo. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por el acceso potencial a múltiples sistemas conectados.
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Uso de un gestor centralizado de secretos, escaneo automático de credenciales en los flujos de integración continua (CI/CD), rotación periódica de credenciales y capacitación del desarrollador en manejo de secretos.

Nota. Elaboración Propia

Riesgo 3: Uso de estación de trabajo del desarrollador como vector de compromiso

Capa de Seguridad por Profundidad	Capa humana y capa de host.
Brecha	Estación de trabajo con controles de seguridad insuficientes (antivirus, cifrado de disco o actualizaciones) y descarga de dependencias o herramientas de fuentes no confiables.
Amenaza	Compromiso del equipo del desarrollador mediante malware o dependencias maliciosas que expone el código fuente y las credenciales de acceso al entorno.
Evaluación MAGERIT	Probabilidad: media. Impacto: 7 (alto). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: externo (ataque a la cadena de suministro) o interno negligente. Contenedor: estación de trabajo y entorno IDE / CI-CD. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media-alta, por ser puerta de entrada al código y a los sistemas de desarrollo.
Nivel de Riesgo Resultante	Alto

Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Endurecimiento de la estación de trabajo (cifrado de disco, EDR y parches), verificación de dependencias, uso de repositorios de paquetes confiables y capacitación en higiene de seguridad.

Nota. Elaboración Propia

Consolidación del Tratamiento de Riesgos / Solución por Criticidad

PENDIENTE POR TODO EL EQUIPO

EVALUACIÓN DE RIESGOS POR ACTIVO ASIGNADO

Activo 1 (Ambiente de Producción): Datos de clientes

Riesgo 1: Acceso no autorizado a la base de datos de producción

Capa de Seguridad por Profundidad	Capa de aplicación y capa de datos, dentro del modelo de defensa en profundidad.
Brecha	Validación de entradas insuficiente y controles de acceso basados en roles (RBAC) deficientes, lo que permite consultas no previstas sobre la base de datos.
Amenaza	Actor externo que aprovecha una vulnerabilidad de inyección (por ejemplo, inyección SQL) para extraer o modificar datos de clientes.
Evaluación MAGERIT	Probabilidad: alta. Impacto: 9 (muy alto), según la escala de valoración de MAGERIT. Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).
Evaluación OCTAVE	Activo de información esencial dentro del enfoque OCTAVE Allegro. Actor: externo. Contenedor: servidor de base de datos de producción. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: muy alta, por tratarse del activo con mayor peso en los criterios de impacto financiero y reputacional (Caralli et al., 2007).
Nivel de Riesgo Resultante	Crítico
Tratamiento del Riesgo	Mitigar.

Solución Específica de Mitigación	Uso de consultas parametrizadas u ORM, implementación de un firewall de aplicaciones web (WAF), revisiones periódicas de código seguro y aplicación del principio de mínimo privilegio en los accesos a la base de datos, en línea con las recomendaciones del OWASP Top 10 (OWASP Foundation, 2021).
--	---

Nota. Elaboración Propia

Riesgo 2: Exposición de información por deficiencias de cifrado

Capa de Seguridad por Profundidad	Capa de datos y capa de red (transporte de la información).
Brecha	Datos sensibles almacenados sin cifrado adecuado o transmitidos mediante protocolos de cifrado obsoletos.
Amenaza	Interceptación de la comunicación (ataque de intermediario) o sustracción de medios de almacenamiento, con la consecuente exposición de datos de clientes.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: externo o interno negligente. Contenedor: base de datos y canal de transmisión hacia servicios en la nube. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por el impacto reputacional y regulatorio asociado a datos personales.
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar.

Solución Específica de Mitigación	Cifrado de datos en reposo (AES-256), uso de TLS en su versión más reciente para datos en tránsito, administración de llaves mediante un gestor centralizado (KMS) y rotación periódica de certificados.
--	--

Nota. Elaboración Propia

Riesgo 3: Uso indebido de privilegios por parte de personal interno

Capa de Seguridad por Profundidad	Capa humana y capa de aplicación (gobierno de accesos).
Brecha	Ausencia de segregación de funciones y falta de auditoría sobre las cuentas con privilegios administrativos.
Amenaza	Colaborador con acceso legítimo que consulta, extrae o modifica datos de clientes sin autorización ni justificación de negocio (amenaza interna deliberada o negligente).
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: interno malicioso o interno negligente. Contenedor: aplicación de gestión de clientes y cuentas con privilegios administrativos. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por evidenciar una debilidad de gobierno interno más que puramente técnica.
Nivel de Riesgo Resultante	Alto
Tratamiento del Riesgo	Mitigar y controlar.
Solución Específica de Mitigación	Segregación de funciones, registro y monitoreo (logging) de accesos privilegiados con trazabilidad independiente, doble autorización para operaciones sensibles y programas periódicos de capacitación en seguridad de la información.

Nota. Elaboración Propia

Activo 2 (Ambiente de Pruebas): Datos de prueba anonimizados

Riesgo 1: Anonimización insuficiente y reidentificación de datos

Capa de Seguridad por Profundidad	Capa de aplicación y capa de datos.
Brecha	Proceso de anonimización débil, como el uso de seudonimización reversible o técnicas que no eliminan de forma efectiva los identificadores indirectos.
Amenaza	Reidentificación de personas mediante la correlación de los datos de prueba con otras fuentes de información disponibles.
Evaluación MAGERIT	Probabilidad: media. Impacto: 5 (medio). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: interno negligente o tercero con acceso al ambiente. Contenedor: base de datos de pruebas. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media, relevante sobre todo por el cumplimiento normativo en materia de protección de datos personales.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Aplicación de técnicas de anonimización robustas (por ejemplo, k-anonimato o enmascaramiento dinámico de datos) y validación periódica de la efectividad del proceso de anonimización.

Nota. Elaboración Propia

Riesgo 2: Acceso no controlado al ambiente de pruebas

Capa de Seguridad por Profundidad	Capa de red y capa de aplicación.
Brecha	Ausencia de segmentación de red entre el ambiente de pruebas y producción, así como uso de credenciales compartidas entre desarrolladores o terceros.
Amenaza	Persona no autorizada, incluyendo contratistas externos, accede al ambiente de pruebas y extrae información sensible.
Evaluación MAGERIT	Probabilidad: media. Impacto: 5 (medio). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: externo (contratista o tercero) o interno negligente. Contenedor: red y credenciales del ambiente de pruebas. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: media, por su conexión indirecta con activos críticos de producción.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Segmentación de red mediante VLAN dedicada, autenticación multifactor y asignación de cuentas individuales con expiración automática de acceso.

Nota. Elaboración Propia

Riesgo 3: Retención prolongada de datos de prueba obsoletos

Capa de Seguridad por Profundidad	Capa de datos.
Brecha	Falta de una política formal de retención y eliminación de los datos utilizados en los ambientes de prueba.
Amenaza	Acumulación de datos de prueba antiguos que incrementa innecesariamente la superficie de ataque del sistema.

Evaluación MAGERIT	Probabilidad: baja. Impacto: 3 (medio-bajo). Dimensión comprometida: confidencialidad [C]. Riesgo resultante: moderado-bajo.
Evaluación OCTAVE	Actor: no aplica un actor específico; vulnerabilidad de tipo organizativo. Contenedor: repositorios de almacenamiento de datos de prueba. Requisito de seguridad afectado: confidencialidad. Prioridad de protección: baja-media, de carácter preventivo.
Nivel de Riesgo Resultante	Moderado-bajo
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Definición de una política de retención con eliminación automática de datos vencidos y establecimiento de un ciclo de vida claro para los datos de prueba.

Nota. Elaboración Propia

Activo 3 (Ambiente de Desarrollo): Código fuente y credenciales

Riesgo 1: Exposición de credenciales dentro del código fuente

Capa de Seguridad por Profundidad	Capa de aplicación.
Brecha	Prácticas de codificación deficientes que incluyen credenciales escritas directamente en el código (hardcoded secrets) y ausencia de escaneo automatizado de secretos.
Amenaza	Filtración de credenciales a través de un repositorio comprometido, permitiendo el acceso no autorizado a sistemas críticos.
Evaluación MAGERIT	Probabilidad: alta. Impacto: 9 (muy alto). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: crítico.
Evaluación OCTAVE	Actor: externo que explota credenciales filtradas, o interno negligente. Contenedor: repositorio de código y flujos de integración continua (CI/CD). Requisito de seguridad afectado: confidencialidad. Prioridad de protección: muy alta, ya que compromete potencialmente la totalidad de los sistemas conectados.

Nivel de Riesgo	Crítico
Resultante	
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Implementación de un gestor centralizado de secretos, escaneo automático de credenciales dentro de los flujos de integración continua (CI/CD) y rotación periódica de credenciales.

Nota. Elaboración Propia

Riesgo 2: Acceso no autorizado al repositorio de código fuente

Capa de Seguridad por Profundidad	Capa de aplicación y capa de red.
Brecha	Controles de acceso débiles al repositorio, sin autenticación multifactor y con permisos excesivos otorgados a usuarios.
Amenaza	Sustracción de propiedad intelectual o inserción de código malicioso por parte de un actor no autorizado.
Evaluación MAGERIT	Probabilidad: media. Impacto: 8 (alto). Dimensiones comprometidas: confidencialidad [C] e integridad [I]. Riesgo resultante: alto.
Evaluación OCTAVE	Actor: externo o interno comprometido. Contenedor: plataforma de control de versiones (repositorio Git). Requisito de seguridad afectado: confidencialidad. Prioridad de protección: alta, por la pérdida potencial de ventaja competitiva.
Nivel de Riesgo	Alto
Resultante	
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Autenticación multifactor obligatoria, control de acceso basado en roles y revisión obligatoria de solicitudes de cambio (pull requests) antes de su integración.

Nota. Elaboración Propia

Riesgo 3: Ausencia de verificación de integridad del código

Capa de Seguridad por Profundidad	Capa de aplicación.
Brecha	Falta de mecanismos que garanticen que el código integrado proviene de una fuente confiable y no ha sido alterado.
Amenaza	Modificación no autorizada del código fuente que da lugar a un ataque a la cadena de suministro de software.
Evaluación MAGERIT	Probabilidad: baja. Impacto: 8 (alto). Dimensión comprometida: integridad [I]. Riesgo resultante: moderado.
Evaluación OCTAVE	Actor: externo (ataque a la cadena de suministro) o interno malicioso. Contenedor: repositorio de código y pipeline de despliegue. Requisito de seguridad afectado: integridad. Prioridad de protección: media-alta, por su efecto sobre la confianza del producto entregado a los clientes.
Nivel de Riesgo Resultante	Moderado
Tratamiento del Riesgo	Mitigar.
Solución Específica de Mitigación	Firma digital de las confirmaciones de cambios (commits), políticas de protección de ramas (branch protection) y revisión de código obligatoria previa a la integración.

Nota. Elaboración Propia

Consolidación del Tratamiento de Riesgos / Solución por Criticidad

PENDIENTE POR TODO EL EQUIPO

EVALUACIÓN DE RIESGOS POR ACTIVO ASIGNADO

Activo 1 (Ambiente de Producción): Servidor de Base de Datos

Riesgo 1: Acceso físico no controlado al centro de datos

El servidor de base de datos de producción es el activo esencial del cual dependen los servicios de facturación y la información de clientes de la organización. Si el espacio físico donde se aloja no cuenta con controles de acceso adecuados, cualquier persona con acceso al edificio podría llegar hasta el equipo sin que exista un registro de quién estuvo allí ni cuándo.

- **Capa de Seguridad por Profundidad:** Seguridad Física, dentro del modelo de defensa en profundidad.
- **Brecha:** Ausencia de control de acceso físico (tarjeta o biometría) y de un registro de visitantes en el cuarto de servidores donde reside el equipo de producción.
- **Amenaza:** Persona no autorizada que ingresa físicamente a las instalaciones y sustrae, manipula o sabotea el servidor de base de datos.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Baja
Impacto	7 (alto), según la escala de valoración de MAGERIT
Dimensiones comprometidas	Disponibilidad e integridad
Riesgo resultante	Moderado

OCTAVE

Actor	Externo (intruso físico) o interno sin autorización de área
Contenedor	Sala de servidores de la organización
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Alta, por sostener el servicio de facturación y los datos de clientes

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Control de acceso físico con tarjeta o biometría al cuarto de servidores, circuito cerrado de videovigilancia y bitácora de visitantes con doble autorización.

Riesgo 2: Exposición de puertos de administración a la red interna

La administración remota del servidor a través de puertos abiertos sin restricción convierte a cualquier equipo comprometido dentro de la red interna en una posible vía de acceso hacia la

base de datos. Este riesgo cobra especial relevancia porque no requiere que el atacante vulnere el perímetro externo, sino únicamente moverse lateralmente una vez dentro de la red.

- **Capa de Seguridad por Profundidad:** Seguridad de Red.
- **Brecha:** Puertos de administración remota (SSH/RDP) del servidor expuestos sin restricción dentro de la red interna.
- **Amenaza:** Acceso remoto no autorizado desde un equipo comprometido de la red interna hacia el servidor de base de datos.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	8 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Alto

OCTAVE

Actor	Interno comprometido o externo que ya vulneró otro equipo interno
Contenedor	Red interna y puertos de administración del servidor
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Alta, por habilitar acceso administrativo total sobre el activo

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Restricción de puertos de administración mediante listas de control de acceso (ACL), segmentación en una VLAN de gestión y acceso únicamente mediante VPN con autenticación multifactor.

Riesgo 3: Sistema operativo del servidor desactualizado

Un servidor sin actualizaciones recientes conserva vulnerabilidades ya documentadas públicamente, lo que reduce el esfuerzo que un atacante necesita para comprometerlo. Al tratarse del servidor que sostiene el activo esencial de la organización, cualquier vulnerabilidad no corregida representa una vía de entrada de alto impacto.

- **Capa de Seguridad por Profundidad:** Seguridad de Host.

- **Brecha:** Sistema operativo y motor de base de datos sin las actualizaciones de seguridad más recientes.
- **Amenaza:** Explotación de vulnerabilidades conocidas y públicamente documentadas para obtener control del servidor.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Alta
Impacto	9 (muy alto)
Dimensiones comprometidas	Confidencialidad, integridad y disponibilidad
Riesgo resultante	Crítico

OCTAVE

Actor	Externo que emplea herramientas automatizadas de explotación
Contenedor	Sistema operativo del servidor de base de datos
Requisito de seguridad afectado	Disponibilidad e integridad
Prioridad de protección	Muy alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Procedimiento formal de gestión de parches con ventanas de mantenimiento periódicas, análisis de vulnerabilidades recurrente y plazos máximos de corrección por banda de severidad conforme al CVSS (Forum of Incident Response and Security Teams, 2019).

Riesgo 4: Configuración por defecto del motor de base de datos

Dejar el motor de base de datos con su configuración de instalación y sin controles de validación de entradas expone directamente la información que administra a técnicas de manipulación de consultas, una de las formas más comunes de comprometer bases de datos de producción.

- **Capa de Seguridad por Profundidad:** Seguridad de Aplicación.
- **Brecha:** Motor de base de datos instalado con credenciales y configuración por defecto, y validación de entradas insuficiente.
- **Amenaza:** Inyección SQL o escalamiento de privilegios que permite extraer o modificar datos de producción.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	8 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Alto

OCTAVE

Actor	Externo
Contenedor	Motor de base de datos y aplicaciones que lo consultan
Requisito de seguridad afectado	Confidencialidad e integridad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cambio de credenciales por defecto, uso de consultas parametrizadas u ORM, firewall de aplicaciones web (WAF) y revisiones de código seguro conforme al OWASP Top 10 (OWASP Foundation, 2021).

Riesgo 5: Ausencia de cifrado en datos en reposo

Almacenar la información sin cifrado significa que cualquier copia no autorizada de los archivos del servidor, ya sea por acceso indebido o por sustracción de un respaldo, deja los datos completamente legibles, sin ninguna barrera adicional de protección.

- **Capa de Seguridad por Profundidad:** Seguridad de Datos.
- **Brecha:** Los archivos de la base de datos y sus respaldos no cuentan con cifrado en reposo.
- **Amenaza:** Fuga de información confidencial ante acceso no autorizado a los archivos o a un medio de respaldo sustraído.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	9 (muy alto)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Alto

OCTAVE

Actor	Externo o interno negligente
--------------	------------------------------

Contenedor	Archivos de base de datos y medios de respaldo
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Muy alta, por tratarse del activo de mayor valor de la organización

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cifrado en reposo (AES-256) de la base de datos y sus respaldos, con administración de llaves mediante un gestor centralizado (KMS).

Riesgo 6: Cuentas administrativas compartidas

Cuando varias personas usan una misma cuenta con privilegios de administrador, se pierde la posibilidad de identificar individualmente quién realizó una acción determinada sobre el servidor, lo que debilita tanto la prevención como la investigación de incidentes.

- **Capa de Seguridad por Profundidad:** Gestión de Identidad y Acceso.
- **Brecha:** Uso de una cuenta administrativa compartida entre varios técnicos, sin trazabilidad individual de las acciones.
- **Amenaza:** Uso indebido de credenciales privilegiadas sin que la acción pueda atribuirse a una persona específica.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	7 (alto)
Dimensiones comprometidas	Confidencialidad y trazabilidad
Riesgo resultante	Alto

OCTAVE

Actor	Interno malicioso o interno negligente
Contenedor	Cuentas administrativas del servidor
Requisito de seguridad afectado	Trazabilidad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar y controlar.
- **Solución Específica de Mitigación:** Cuentas nominales e individuales, gestión de accesos privilegiados (PAM) y doble autorización para operaciones sensibles.

Riesgo 7: Falta de registro centralizado de eventos

Sin un registro centralizado de lo que ocurre en el servidor, la organización carece de visibilidad sobre accesos y cambios, lo cual retrasa la detección de cualquier actividad anómala y dificulta reconstruir lo sucedido después de un incidente.

- **Capa de Seguridad por Profundidad:** Monitoreo y Respuesta.
- **Brecha:** Ausencia de registro (logging) centralizado de los accesos y operaciones realizadas sobre el servidor.
- **Amenaza:** Detección tardía de un incidente de seguridad, lo que prolonga el tiempo de exposición del activo.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Trazabilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico, pues corresponde a una vulnerabilidad de tipo organizativo
Contenedor	Infraestructura de monitoreo
Requisito de seguridad afectado	Trazabilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Implementación de un sistema de gestión de eventos e información de seguridad (SIEM) con trazabilidad independiente y alertas automáticas ante comportamiento anómalo.

Riesgo 8: Respaldos no probados periódicamente

Contar con un proceso de respaldo no garantiza por sí solo la recuperación de la información. Si nunca se verifica que los respaldos realmente puedan restaurarse, existe el riesgo de descubrir que son inútiles justo en el momento en que más se necesitan.

- **Capa de Seguridad por Profundidad:** Continuidad y Respaldo.

- **Brecha:** Los respaldos del servidor se generan de forma programada, pero no se realizan pruebas periódicas de restauración.
- **Amenaza:** Pérdida irreversible de datos ante un fallo de hardware o un incidente de ransomware, al descubrirse que el respaldo no es restaurable.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Baja
Impacto	9 (muy alto)
Dimensiones comprometidas	Disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico, pues corresponde a una vulnerabilidad de proceso
Contenedor	Infraestructura de respaldo
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Alta por su efecto potencialmente catastrófico si se materializa

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Pruebas de restauración periódicas programadas, respaldos cifrados en un sitio independiente y contratación de un seguro de ciberseguridad como respaldo financiero.

Riesgo 9: Reglas de firewall obsoletas

Un firewall con reglas desactualizadas o demasiado permisivas deja de cumplir su función de contención, permitiendo que un atacante que ya ingresó a otro punto de la red se desplace sin obstáculos hasta el servidor de base de datos.

- **Capa de Seguridad por Profundidad:** Seguridad Perimetral.
- **Brecha:** Reglas del firewall perimetral desactualizadas o excesivamente permisivas hacia el segmento donde reside el servidor.
- **Amenaza:** Movimiento lateral de un atacante que ya comprometió otro equipo de la red hacia el servidor de base de datos.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	7 (alto)
Dimensiones comprometidas	Confidencialidad, integridad y disponibilidad
Riesgo resultante	Alto

OCTAVE

Actor	Externo que ya obtuvo un punto de apoyo interno
Contenedor	Firewall perimetral y segmentación de red
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Revisión y depuración periódica de las reglas de firewall, segmentación de red mediante una VLAN dedicada para el servidor y monitoreo de tráfico anómalo.

Riesgo 10: Falta de procedimiento de gestión de parches

La ausencia de un proceso formal para aplicar actualizaciones de seguridad no es un problema técnico aislado, sino una debilidad organizativa que deja abiertas de manera simultánea varias de las vulnerabilidades descritas en los riesgos anteriores.

- **Capa de Seguridad por Profundidad:** Concientización y Procesos.
- **Brecha:** Ausencia de un procedimiento formal y calendarizado para la aplicación de parches de seguridad.
- **Amenaza:** Explotación de vulnerabilidades ya conocidas y corregibles que permanecen sin remediar por falta de un proceso definido.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Alta
Impacto	9 (muy alto)
Dimensiones comprometidas	Confidencialidad, integridad y disponibilidad
Riesgo resultante	Crítico

OCTAVE

Actor	No aplica un actor específico, pues corresponde a una deficiencia estructural del tipo que MAGERIT cataloga como debilidad organizativa
Contenedor	Proceso de administración del servidor
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Muy alta, por habilitar de forma simultánea varias de las amenazas anteriores

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Definición de una política formal de gestión de parches con responsables asignados, ventanas de mantenimiento periódicas y verificación posterior de la aplicación de cada parche.

Activo 2 (Ambiente de Pruebas): Servidor de pruebas

Riesgo 1: Ubicación física sin resguardo del servidor de pruebas

El servidor de pruebas suele recibir menos atención en materia de seguridad física que el de producción, precisamente por considerarse un ambiente de menor criticidad. Sin embargo, dejarlo en un área común sin resguardo lo expone a manipulación o daño accidental por parte de personal ajeno al proyecto.

- **Capa de Seguridad por Profundidad:** Seguridad Física.
- **Brecha:** Servidor de pruebas ubicado en un área común, sin gabinete o rack asegurado.
- **Amenaza:** Acceso físico no autorizado o daño accidental al equipo por personal ajeno al proyecto.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	5 (medio)
Dimensiones comprometidas	Disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	Interno no autorizado (cualquier colaborador con acceso al área)
Contenedor	Sala o rack donde se ubica el servidor de pruebas

Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Reubicación del equipo en un rack con cerradura dentro de un área restringida y bloqueo de acceso al área.

Riesgo 2: Ausencia de segmentación hacia el ambiente de producción

Un ambiente de pruebas suele configurarse con controles de seguridad menos estrictos que producción, lo cual es razonable si ambos ambientes están debidamente separados. El problema surge cuando esa separación de red no existe, porque entonces la menor seguridad de pruebas se convierte en una puerta de entrada hacia producción.

- **Capa de Seguridad por Profundidad:** Seguridad de Red.
- **Brecha:** Ausencia de segmentación de red entre el servidor de pruebas y el segmento de producción.
- **Amenaza:** Un atacante que compromete el servidor de pruebas, de menor exigencia de seguridad, lo utiliza como punto de apoyo hacia producción.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	8 (alto), por el efecto indirecto sobre producción
Dimensiones comprometidas	Confidencialidad, integridad y disponibilidad
Riesgo resultante	Alto

OCTAVE

Actor	Externo o interno negligente
Contenedor	Red de pruebas conectada sin restricción a producción
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Alta, por su efecto indirecto sobre activos críticos de producción

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.

- **Solución Específica de Mitigación:** Segmentación mediante una VLAN dedicada exclusivamente al ambiente de pruebas, con reglas de firewall que impidan el tráfico directo hacia producción.

Riesgo 3: Servidor de pruebas sin bastionado (hardening)

Instalar un servidor y dejarlo con la configuración que trae por defecto, con servicios innecesarios habilitados y cuentas sin cambiar, es una práctica común en ambientes de pruebas por la urgencia de tenerlos disponibles rápido, pero deja expuestas configuraciones que un atacante puede identificar y aprovechar fácilmente.

- **Capa de Seguridad por Profundidad:** Seguridad de Host.
- **Brecha:** Servidor de pruebas con configuración por defecto, servicios innecesarios habilitados y cuentas por defecto sin deshabilitar.
- **Amenaza:** Explotación de configuraciones débiles para tomar control del servidor.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Moderado

OCTAVE

Actor	Externo o interno
Contenedor	Sistema operativo base del servidor de pruebas
Requisito de seguridad afectado	Integridad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Aplicación de una guía de bastionado (hardening) estándar antes de habilitar el servidor y deshabilitación de todo servicio innecesario.

Riesgo 4: Ausencia de aislamiento entre proyectos de prueba

Cuando distintos equipos comparten el mismo servidor de pruebas sin ningún mecanismo de aislamiento, un error o una prueba mal controlada en un proyecto puede afectar la disponibilidad o integridad de las pruebas de otro equipo que no tiene ninguna relación con el incidente.

- **Capa de Seguridad por Profundidad:** Seguridad de Aplicación.

- **Brecha:** Falta de aislamiento (por máquinas virtuales o contenedores) entre distintos proyectos o equipos que comparten el mismo servidor de pruebas.
- **Amenaza:** Un proceso o aplicación de prueba comprometida afecta a otras pruebas que se ejecutan en el mismo servidor.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	5 (medio)
Dimensiones comprometidas	Integridad y disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	Interno negligente (equipo que ejecuta pruebas sin control)
Contenedor	Entorno de virtualización o contenedores del servidor
Requisito de seguridad afectado	Integridad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Aislamiento mediante máquinas virtuales o contenedores independientes por proyecto, con límites de recursos claramente definidos.

Riesgo 5: Discos sin cifrado en el servidor de pruebas

Aun cuando los datos utilizados en pruebas debieran estar anonimizados, el servidor puede llegar a almacenar información sensible de forma temporal durante los ciclos de prueba. Si el disco no está cifrado, esa información queda expuesta ante cualquier acceso no autorizado al hardware.

- **Capa de Seguridad por Profundidad:** Seguridad de Datos.
- **Brecha:** Ausencia de cifrado en los discos donde se almacenan temporalmente los datos utilizados durante las pruebas.
- **Amenaza:** Exposición de información si el disco físico o virtual es sustraído o accedido sin autorización.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Baja
---------------------	------

Impacto	6 (alto)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Moderado
OCTAVE	
Actor	Externo o interno negligente
Contenedor	Discos de almacenamiento del servidor de pruebas
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Media, en la medida en que los datos alojados deben corresponder a información previamente anonimizada

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cifrado de disco completo en el servidor de pruebas y eliminación segura de los datos temporales al finalizar cada ciclo de pruebas.

Riesgo 6: Credenciales de acceso compartidas al servidor

Es habitual que varios desarrolladores o incluso terceros contratistas compartan una misma credencial de acceso al servidor de pruebas por simple comodidad operativa, pero esto impide saber con certeza quién accedió y elimina la posibilidad de revocar el acceso de una sola persona sin afectar a las demás.

- **Capa de Seguridad por Profundidad:** Gestión de Identidad y Acceso.
- **Brecha:** Credenciales de acceso al servidor de pruebas compartidas entre desarrolladores y terceros.
- **Amenaza:** Acceso no controlado de contratistas o personal externo al servidor mediante credenciales genéricas.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	5 (medio)
Dimensiones comprometidas	Confidencialidad y trazabilidad
Riesgo resultante	Moderado

OCTAVE

Actor	Externo (contratista) o interno negligente
Contenedor	Cuentas de acceso al sistema operativo del servidor

Requisito de seguridad afectado	Trazabilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cuentas individuales con autenticación multifactor y expiración automática de acceso al finalizar el contrato o la tarea.

Riesgo 7: Falta de monitoreo de disponibilidad y accesos

Al no monitorear la disponibilidad ni los accesos al servidor de pruebas, la organización solo se entera de un problema, ya sea un mal uso o una caída del servicio, cuando el equipo de desarrollo o pruebas lo reporta, lo que puede tardar horas o incluso días.

- **Capa de Seguridad por Profundidad:** Monitoreo y Respuesta.
- **Brecha:** Ausencia de monitoreo de disponibilidad y de accesos sobre el servidor de pruebas.
- **Amenaza:** Uso indebido o caída prolongada del servidor sin ser detectada, retrasando los ciclos de prueba de todo el equipo.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	4 (medio)
Dimensiones comprometidas	Disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico
Contenedor	Infraestructura de monitoreo
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Baja-media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Habilitación de monitoreo básico de disponibilidad y de accesos, con alertas dirigidas al equipo responsable.

Riesgo 8: Ausencia de respaldo del servidor de pruebas

Los servidores de pruebas suelen excluirse de los esquemas de respaldo por considerarse desechables, pero en la práctica acumulan configuraciones, scripts y avances de trabajo cuya pérdida puede retrasar significativamente el cronograma del proyecto.

- **Capa de Seguridad por Profundidad:** Continuidad y Respaldo.
- **Brecha:** El servidor de pruebas no cuenta con ningún esquema de respaldo ni de redundancia.
- **Amenaza:** Pérdida de configuraciones y avances de prueba ante un fallo de hardware, retrasando la entrega del proyecto.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	5 (medio)
Dimensiones comprometidas	Disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico
Contenedor	Configuración e imágenes del servidor de pruebas
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Respaldo periódico de la configuración e imágenes del servidor, y documentación del procedimiento de reconstrucción.

Riesgo 9: Exposición directa del servidor de pruebas a Internet

Publicar el servidor de pruebas directamente en Internet, sin ningún control de acceso, lo vuelve visible para los barridos automatizados que exploran constantemente direcciones IP en busca de servicios expuestos, independientemente de si el equipo tiene intención de recibir tráfico externo.

- **Capa de Seguridad por Profundidad:** Seguridad Perimetral.
- **Brecha:** Servidor de pruebas expuesto directamente a Internet sin restricciones adecuadas de acceso.

- **Amenaza:** Barridos automatizados detectan y acceden al servidor de pruebas por estar expuesto sin control perimetral.

- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Alta
Impacto	6 (alto)
Dimensiones comprometidas	Confidencialidad y disponibilidad
Riesgo resultante	Alto

OCTAVE

Actor	Externo, mediante herramientas automatizadas
Contenedor	Interfaz de red expuesta a Internet
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Restricción de acceso mediante VPN corporativa o listas de direcciones IP permitidas, eliminando la exposición directa a Internet.

Riesgo 10: Ausencia de un ciclo de vida formal del servidor de pruebas

Sin un procedimiento que defina cuándo se crea y, sobre todo, cuándo se da de baja un servidor de pruebas, es común que estos equipos permanezcan activos mucho después de que el proyecto que los originó ha terminado, acumulando configuraciones obsoletas que nadie revisa.

- **Capa de Seguridad por Profundidad:** Concientización y Procesos.
- **Brecha:** Falta de lineamientos sobre el ciclo de vida del servidor de pruebas: creación, uso y baja.
- **Amenaza:** El servidor permanece activo con configuraciones de prueba obsoletas después de concluido el proyecto, ampliando innecesariamente la superficie de ataque.

- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	4 (medio)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico, pues corresponde a una vulnerabilidad de tipo organizativo
Contenedor	Proceso de gestión del ciclo de vida del servidor
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Baja-media, de carácter preventivo

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Definición de un procedimiento formal de alta y baja de servidores de prueba, con fecha de expiración y desmantelamiento programado.

Activo 3 (Ambiente de Desarrollo): Estación de trabajo del desarrollador***Riesgo 1: Ausencia de bloqueo automático en equipos móviles***

La naturaleza móvil del trabajo de desarrollo, que con frecuencia se realiza fuera de la oficina, aumenta la probabilidad de que el equipo quede desatendido en un espacio público. Si además no se bloquea automáticamente, cualquier persona cercana podría acceder directamente a la sesión activa.

- **Capa de Seguridad por Profundidad:** Seguridad Física.
- **Brecha:** Estación de trabajo (equipo portátil) sin bloqueo automático de sesión, utilizada con frecuencia en espacios de coworking o públicos.
- **Amenaza:** Robo o acceso físico no autorizado al equipo con la sesión desbloqueada, exponiendo el código fuente y las credenciales almacenadas localmente.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	7 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Alto

OCTAVE

Actor	Externo (hurto oportunista) o persona no autorizada en el entorno de trabajo
Contenedor	Equipo portátil del desarrollador
Requisito de seguridad afectado	Confidencialidad

Prioridad de protección	Alta
--------------------------------	------

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cifrado de disco completo, bloqueo automático de sesión tras un breve periodo de inactividad y capacidad de localización y borrado remoto del equipo.

Riesgo 2: Conexión a redes no confiables sin VPN

Trabajar desde redes públicas sin las protecciones adecuadas expone el tráfico del desarrollador, incluidas credenciales y fragmentos de código, a la posibilidad de ser interceptado por cualquier otro dispositivo conectado a esa misma red.

- **Capa de Seguridad por Profundidad:** Seguridad de Red.
- **Brecha:** Conexión de la estación de trabajo a redes Wi-Fi públicas o no confiables sin el uso de una VPN.
- **Amenaza:** Interceptación de tráfico o ataque de intermediario mientras el desarrollador trabaja de forma remota.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Moderado

OCTAVE

Actor	Externo
Contenedor	Conexión de red del equipo del desarrollador
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Uso obligatorio de VPN corporativa para toda conexión remota y restricción de acceso a redes no verificadas mediante política de dispositivo.

Riesgo 3: Estación de trabajo sin actualizaciones ni antimalware

Al igual que ocurre con los servidores, una estación de desarrollo desactualizada conserva vulnerabilidades conocidas. La diferencia es que, en este caso, el equipo comprometido tiene acceso directo al código fuente y a las credenciales que el desarrollador usa a diario.

- **Capa de Seguridad por Profundidad:** Seguridad de Host.
- **Brecha:** Estación de trabajo sin actualizaciones de seguridad recientes ni solución antimalware vigente.
- **Amenaza:** Compromiso del equipo mediante software malicioso que expone el código fuente y las credenciales locales.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	7 (alto)
Dimensiones comprometidas	Confidencialidad e integridad
Riesgo resultante	Alto

OCTAVE

Actor	Externo (a través de la cadena de suministro de software) o interno negligente
Contenedor	Sistema operativo del equipo
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Gestión centralizada de actualizaciones, solución de detección y respuesta en el equipo (EDR) y verificación periódica del cumplimiento de seguridad del equipo.

Riesgo 4: Instalación de software no autorizado

Los desarrolladores suelen instalar herramientas y extensiones de terceros para agilizar su trabajo, una práctica necesaria para la productividad pero que, sin ningún control, abre la puerta a que una de esas herramientas resulte ser maliciosa o esté comprometida.

- **Capa de Seguridad por Profundidad:** Seguridad de Aplicación.

- **Brecha:** Instalación de software o extensiones de terceros (por ejemplo, plugins del entorno de desarrollo) sin control ni validación previa.
- **Amenaza:** Introducción de una dependencia o extensión maliciosa que compromete el entorno de desarrollo local.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Integridad y confidencialidad
Riesgo resultante	Moderado

OCTAVE

Actor	Externo (cadena de suministro de software) o interno negligente
Contenedor	Entorno de desarrollo integrado (IDE) y herramientas instaladas en la estación
Requisito de seguridad afectado	Integridad
Prioridad de protección	Media-alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Lista blanca de software y extensiones permitidas, verificación de firmas de paquetes y restricción de privilegios de instalación.

Riesgo 5: Código fuente y credenciales sin cifrado local

Es común que el desarrollador mantenga copias locales del código y, en ocasiones, credenciales de acceso a otros sistemas directamente en su equipo. Si el disco no está cifrado, esa información queda expuesta ante la pérdida o sustracción física del equipo.

- **Capa de Seguridad por Profundidad:** Seguridad de Datos.
- **Brecha:** Copias locales del código fuente y credenciales almacenadas sin cifrado en el disco de la estación de trabajo.
- **Amenaza:** Exposición de código fuente y credenciales si el disco es extraído o accedido fuera del sistema operativo.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	8 (alto)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Alto
OCTAVE	
Actor	Externo o interno negligente
Contenedor	Disco local de la estación de trabajo
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Cifrado de disco completo en la estación de trabajo y prohibición de almacenar credenciales en texto plano fuera de un gestor centralizado de secretos.

Riesgo 6: Privilegios de administrador local permanentes

Otorgar privilegios administrativos permanentes facilita el trabajo diario del desarrollador, pero también significa que cualquier error, negligencia o compromiso del equipo tiene el mismo alcance que tendría un atacante con control total sobre el sistema.

- **Capa de Seguridad por Profundidad:** Gestión de Identidad y Acceso.
- **Brecha:** Desarrollador con privilegios de administrador local permanentes sobre su propia estación de trabajo.
- **Amenaza:** Uso indebido, deliberado o negligente, de privilegios elevados para deshabilitar controles de seguridad o instalar software no autorizado.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Integridad
Riesgo resultante	Moderado

OCTAVE

Actor	Interno negligente o malicioso
Contenedor	Cuenta local de la estación de trabajo

Requisito de seguridad afectado	Integridad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Aplicación del principio de mínimo privilegio, con elevación temporal y auditada de permisos administrativos en lugar de acceso administrativo permanente.

Riesgo 7: Ausencia de telemetría de seguridad en el equipo

Sin ningún tipo de monitoreo instalado en el equipo, un compromiso puede pasar completamente inadvertido durante semanas, dando tiempo suficiente para que un atacante explore el entorno de desarrollo y busque otros sistemas a los que moverse.

- **Capa de Seguridad por Profundidad:** Monitoreo y Respuesta.
- **Brecha:** Ausencia de un agente de monitoreo o telemetría de seguridad en las estaciones de desarrollo.
- **Amenaza:** Un compromiso del equipo pasa inadvertido durante un periodo prolongado, permitiendo el movimiento del atacante hacia otros sistemas.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Trazabilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico
Contenedor	Infraestructura de monitoreo de endpoints
Requisito de seguridad afectado	Trazabilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Despliegue de un agente de detección y respuesta en el equipo (EDR) con telemetría centralizada y alertas ante comportamiento anómalo.

Riesgo 8: Trabajo almacenado únicamente de forma local

Cuando el avance de un desarrollador depende únicamente del almacenamiento local de su equipo, cualquier falla de hardware, robo o daño accidental puede traducirse en la pérdida de días o semanas de trabajo que no fueron respaldados en ningún otro lugar.

- **Capa de Seguridad por Profundidad:** Continuidad y Respaldo.
- **Brecha:** El avance del desarrollador se almacena únicamente de forma local, sin un respaldo automático.
- **Amenaza:** Pérdida de avances de desarrollo ante fallo, robo o daño del equipo, al no existir un respaldo disponible.
- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	5 (medio)
Dimensiones comprometidas	Disponibilidad
Riesgo resultante	Moderado

OCTAVE

Actor	No aplica un actor específico
Contenedor	Almacenamiento local del equipo
Requisito de seguridad afectado	Disponibilidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Sincronización automática con el repositorio remoto y respaldo periódico de la configuración del entorno de desarrollo.

Riesgo 9: Acceso remoto sin restricción de origen ni dispositivo

Permitir que los recursos de desarrollo se accedan desde cualquier dispositivo, incluidos equipos personales no gestionados por la organización, multiplica los puntos posibles de entrada, ya que la seguridad del sistema termina dependiendo de equipos sobre los cuales no existe ningún control.

- **Capa de Seguridad por Profundidad:** Seguridad Perimetral.
- **Brecha:** Acceso remoto a los recursos de desarrollo desde la estación de trabajo sin restricción de origen ni de dispositivo.

- **Amenaza:** Acceso a los sistemas de desarrollo desde equipos personales no gestionados, ampliando la superficie perimetral expuesta.

- **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Media
Impacto	6 (alto)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Moderado

OCTAVE

Actor	Interno negligente o externo mediante un dispositivo comprometido
Contenedor	Acceso remoto a los recursos de desarrollo
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Media

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Restricción del acceso remoto únicamente a equipos corporativos gestionados, verificados mediante control de la postura de seguridad del dispositivo.

Riesgo 10: Falta de proceso formal de baja de equipos

Cuando un desarrollador deja el proyecto y no existe un procedimiento definido para recuperar su equipo y revocar sus accesos, el riesgo no desaparece junto con la persona: el equipo, las credenciales almacenadas y los accesos activos permanecen fuera del control de la organización.

- **Capa de Seguridad por Profundidad:** Concientización y Procesos.
- **Brecha:** Ausencia de un proceso formal de entrega y retiro de equipos al ingreso o egreso de un desarrollador del proyecto.
- **Amenaza:** Un equipo con código, credenciales o accesos activos permanece en manos de un colaborador que ya no forma parte del proyecto.

• **Evaluación (MAGERIT y OCTAVE):**

MAGERIT

Probabilidad	Baja
Impacto	7 (alto)
Dimensiones comprometidas	Confidencialidad
Riesgo resultante	Moderado

OCTAVE

Actor	Interno (personal recién desvinculado cuyos accesos no han sido revocados)
Contenedor	Proceso de gestión del ciclo de vida del equipo
Requisito de seguridad afectado	Confidencialidad
Prioridad de protección	Media-alta

Nota. Elaboración Propia

- **Tratamiento del Riesgo:** Mitigar.
- **Solución Específica de Mitigación:** Procedimiento formal de baja de personal que incluya la devolución del equipo, la revocación inmediata de accesos y el borrado seguro o la reasignación controlada del dispositivo.

CONCLUSIÓN

El desarrollo del análisis permitió evidenciar que la gestión de riesgos de seguridad de la información debe abordarse de manera integral, considerando no solamente los componentes tecnológicos, sino también los procesos, las personas y las condiciones físicas que intervienen en la operación de los sistemas. La aplicación de MAGERIT permitió valorar los riesgos a partir de la probabilidad y el impacto sobre las dimensiones de confidencialidad, integridad y disponibilidad, mientras que OCTAVE Allegro permitió complementar el análisis desde la perspectiva de los activos de información, sus contenedores, los actores involucrados y las prioridades de protección.

Los resultados muestran la existencia de riesgos de diferentes niveles de criticidad en los ambientes de producción, pruebas y desarrollo. Entre los escenarios de mayor relevancia se encuentran el ransomware, la exposición de credenciales, los accesos no autorizados, la inyección SQL, el compromiso de cuentas privilegiadas y las debilidades en la protección del código fuente. Estos riesgos pueden afectar directamente la confidencialidad, integridad y disponibilidad de la información y, en determinados escenarios, generar consecuencias sobre la continuidad operativa y la protección de los activos críticos.

Ante estas condiciones, las medidas propuestas se orientan principalmente a la mitigación mediante controles de seguridad aplicados en diferentes capas. Entre ellas destacan la implementación de autenticación multifactor, gestión de accesos privilegiados, segmentación de redes, cifrado de información, respaldos, gestión de parches, análisis de seguridad en los procesos de desarrollo, protección de ramas, gestión centralizada de secretos y capacitación del personal. Estas acciones se encuentran alineadas con el principio de defensa en profundidad, mediante el cual diferentes controles actúan de forma complementaria para evitar que la vulneración de una capa comprometa directamente al activo protegido.

El análisis realizado demuestra que la seguridad no debe considerarse como un conjunto aislado de herramientas tecnológicas, sino como un proceso continuo de identificación, evaluación, tratamiento y seguimiento de los riesgos. La priorización de los escenarios críticos y la implementación progresiva de controles permiten fortalecer la postura de seguridad de la organización y reducir su exposición ante amenazas internas y externas. Por ello, mantener actualizados los controles, revisar periódicamente los riesgos y garantizar la continuidad de las operaciones

REFERENCIAS

- Forum of Incident Response and Security Teams. (2019). Common Vulnerability Scoring System version 3.1: Specification document. FIRST. <https://www.first.org/cvss/>
- OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. <https://owasp.org/Top10/>
- Caralli, R. A., Stevens, J. F., Young, L. R., y Wilson, W. R. (2007). Introducing OCTAVE Allegro: Improving the information security risk assessment process. Software Engineering Institute, Carnegie Mellon University.
- International Organization for Standardization. (2018). ISO/IEC 27005: Information technology Security techniques Information security risk management. ISO.
- Ministerio de Hacienda y Administraciones Públicas. (2012a). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método. Gobierno de España.
- Ministerio de Hacienda y Administraciones Públicas. (2012b). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro II: Catálogo de Elementos. Gobierno de España.
- OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. <https://owasp.org/Top10/>
- Caralli, R. A., Stevens, J. F., Young, L. R., y Wilson, W. R. (2007). Introducing OCTAVE Allegro: Improving the information security risk assessment process. Software Engineering Institute, Carnegie Mellon University.
- International Organization for Standardization. (2018). ISO/IEC 27005: Information technology Security techniques Information security risk management. ISO.
- Ministerio de Hacienda y Administraciones Públicas. (2012a). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método. Gobierno de España.
- Ministerio de Hacienda y Administraciones Públicas. (2012b). MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro II: Catálogo de Elementos. Gobierno de España.
- OWASP Foundation. (2021). OWASP Top 10: The ten most critical web application security risks. <https://owasp.org/Top10/>